

# Incident Management and Response Policy

## Purpose

This policy defines the response process for suspected or confirmed security, privacy, availability, or data handling incidents affecting Room Clarity.

## Incident Examples

- Unauthorized access to meeting dashboard data.
- Exposure of meeting transcript content or generated artifacts.
- Compromise of Zoom, RTMS, LLM provider, cloud, or admin credentials.
- Webhook spoofing or replay attempts.
- Vulnerabilities that could permit data exfiltration, privilege escalation, or service abuse.
- Misconfigured retention or deletion behavior.

## Response Roles

- Incident owner: coordinates investigation, containment, communication, remediation, and closure.
- Technical responder: reviews logs, code, deployment state, and access controls.
- Communications owner: prepares user, admin, provider, or marketplace communications when required.

For the current beta stage, these roles may be held by the same operator.

## Response Process

- 1 Triage the report and assign severity.
- 2 Preserve relevant logs, timestamps, deployment versions, and affected routes.
- 3 Contain active exposure by disabling affected endpoints, rotating credentials, revoking tokens, or pausing beta access.
- 4 Investigate root cause and affected data.
- 5 Remediate code, configuration, credentials, or operational procedures.
- 6 Verify the fix with targeted tests and security checks.
- 7 Notify affected users, administrators, providers, or regulators when required.
- 8 Document timeline, impact, root cause, remediation, and follow-up tasks.

## Severity Guidelines

- Critical: confirmed data exposure, credential compromise, or active exploitation.
- High: likely unauthorized access path or bypass of core security control.